

surgic: local AI document redaction

A pipeline that redacts restricted documents with a local AI model on one air-gapped Mac Studio. No cloud services are involved. Documents are read from a read-only SMB share, processed only in RAM, and written back to a second share with signed proof that nothing left the machine.

Built and tested: about 130 automated tests, CI on macOS and network-disabled Linux

Not yet run on the target Mac Studio

For InfoSec and Cloud Engineering review October 2026

Decisions requested from InfoSec

- Accept the software-protected signing key for the pilot, or require the Secure Enclave option.
- Approve the model, Qwen 3.6 27B (qwen3.6:27b), pinned to the exact weight digest recorded at provisioning.
- Set the human-review sampling rate for released documents.

Requested from Cloud and Infrastructure

- A read-only input share and a writable output share on one SMB host, reachable by IP.
- A dedicated VLAN with a static IP for the Mac Studio, carrying only SMB.
- A service account with access to both shares and nothing else.
- Jamf: AirDrop, Handoff and AirPlay Receiver disabled; Wi-Fi and Bluetooth off; FileVault on.

How a document moves

IN	WORKSPACE	STEP 1	STEP 2	STEP 3	STEP 4	OUT
SMB share, read-only	RAM disk only	Rules: regex and Presidio	Local LLM on masked text	Redact the file	Re-scan the output	SMB share, only if clean

A document that fails the re-scan is quarantined. Nothing from it reaches the output share.

Controls and evidence

REQUIREMENT	HOW IT'S ENFORCED	EVIDENCE ON THE OUTPUT SHARE
No network egress	The firewall (pf) blocks everything except SMB to the one share host. Preflight checks that the loaded rules match exactly. A test probe to an outside address must be blocked.	egress_audit.pcap holds 0 packets; pflog_blocked.pcap shows the blocks
No data persistence	All working files live on a RAM disk, which is zero-filled and detached at the end. Core dumps are off and swap is encrypted.	Signed closure.json listing each teardown step and its exit code
No cross-document leakage	Model context is purged for every document, and the model is unloaded after each batch. An unload that can't be verified aborts the run.	Unload and reset counts in the manifest
Structured data never reaches the LLM	Regex and Presidio redact first. The LLM sees placeholders such as [US_SSN_1] , never the values.	Per-document counts in the manifest; values stored only as one-time HMACs

REQUIREMENT	HOW IT'S ENFORCED	EVIDENCE ON THE OUTPUT SHARE
Output is actually clean	Output files are re-extracted and checked for leftover values, then re-run through the detectors, gitleaks and trufflehog.	Per-document scan results; SHA-256 of every input and output

```
pass out quick inet proto tcp from any to <SMB_HOST_IP> port 445 flags S/SA keep state
```

The firewall's only pass rule, shown above. The manifest and closure record are signed (Ed25519). Logs contain no document text, and file names aren't recorded.

How to verify a run

On a separate workstation, using your own copy of the public key:

```
surgic verify manifests/<run>.manifest.json --pubkey pubkey.pem --outputs <share>
surgic verify evidence/<ts>/closure.json      --pubkey pubkey.pem
```

VERIFIED confirms all of the following:

- ✓ Signatures are valid
- ✓ Every output hash matches
- ✓ Nothing quarantined was released
- ✓ Egress capture holds 0 packets
- ✓ Firewall logged blocks
- ✓ RAM disk was wiped

Fail-closed behavior

- Any failed preflight check (firewall, radios, network listeners, RAM disk, read-only input, model hash) stops the run before a document is read.
- Any error on a document quarantines it. Nothing from it is written.
- Test-only shortcuts (mock model, file-based key, skipping preflight) each need an explicit opt-in flag.

Residual risks

- 1

The signing key is software-protected
It's stored in the login Keychain, so someone with the user's login could export it.
Mitigation available: a Secure Enclave key via Jamf (in progress).
- 2

LLM recall is imperfect
Unstructured secrets depend on model quality. In testing, Qwen 3.6 27B caught contextual secrets in prose but missed a client name in a spreadsheet cell.
Recommended: human spot-checks when a new document type is introduced.
- 3

Prompt injection
A document could try to steer the model. The worst case is under-redaction, never exfiltration.
- 4

OCR limits
Text that OCR can't read, such as poor handwriting, can't be detected.
- 5

Memory pressure could cause swapping
Swap is encrypted with an ephemeral key, and the model (about 17 GB) leaves ample headroom.
- 6

Layer-2 traffic isn't filtered by the firewall
This covers ARP and IPv6 neighbor discovery.
Requires: a static IP on a dedicated VLAN.